

Security Best Practices

BASE24[®]



© 2011 by ACI Worldwide, Inc. All rights reserved.

All information contained in this documentation, as well as the software described in it, is confidential and proprietary to ACI Worldwide, Inc., or one of its subsidiaries, is subject to a license agreement, and may be used or copied only in accordance with the terms of such license. Except as permitted by such license, no part of this documentation may be reproduced, stored in a retrieval system, or transmitted in any form or by electronic, mechanical, recording, or any other means, without the prior written permission of ACI Worldwide, Inc., or one of its subsidiaries.

ACI, ACI Worldwide, and the ACI product names used in this documentation are trademarks or registered trademarks of ACI Worldwide, Inc., or one of its subsidiaries.

Other companies' trademarks, service marks, or registered trademarks and service marks are trademarks, service marks, or registered trademarks and service marks of their respective companies.

Contents

Preface	vii
Security Notice Disclaimer	xi
1: Introduction	1-1
Sensitive Information	1-2
Setting Internal Policies	1-3
Protecting Electronic Data	1-3
Protecting Printed Data	1-4
Protecting Systems and Networks	1-4
Using This Document	1-6
2: Security Best Practices	2-1
Security Standard Reference	2-2
Build and Maintain a Secure Network	2-3
Install and Maintain a Firewall Configuration to Protect Data	2-3
Do Not Use Vendor-Supplied Defaults for System Passwords and Other Security Parameters	2-4
Protect Cardholder Data	2-5
Protect Stored Data	2-5
Encrypt Transmission of Personally Identifiable Data and Sensitive Information Across Public Networks	2-5
Maintain a Vulnerability Management Program	2-7
Use and Regularly Update Anti-Virus Software	2-7
Develop and Maintain Secure Systems and Applications	2-7
Implement Strong Access Control Measures	2-8
Restrict Access to Data by Business Need to Know	2-8
Assign a Unique ID to Each Person with Computer Access	2-8
Restrict Physical Access to Cardholder Data	2-9

Regularly Monitor and Test Networks	2-10
Track and Monitor All Access to Network Resources and Cardholder Data	2-10
Regularly Test Security Systems and Processes	2-10
Maintain an Information Security Policy and Incident Response Plan	2-11
Maintain a Policy that Addresses Information Security	2-11
Implement Best Practices for PIN Security and Key Management	2-12
PIN Encryption	2-12
PIN Verification	2-12
Key Handling	2-12
Hardware Security Devices	2-12
3: Security Best Practices in the BASE24 Environment	3-1
Protect Stored Data	3-2
Storing Transaction Information	3-2
Controlling Access to Stored Data	3-5
Masking Displayed Information	3-6
Restrict Access to Data by Business Need-to-Know	3-7
Assign a Unique ID to Each Person with Computer Access	3-9
Administrative IDs	3-9
User IDs	3-9
Passwords	3-10
System Lockout	3-12
Track and Monitor All Access to Network Resources and Cardholder Data	3-13
Using the CLEARONPURGE Option to Wipe Files	3-14
4: Best Practices for PIN Security and Key Management in the BASE24 Environment	4-1
PIN Encryption	4-2
PINs Must be Encrypted	4-2
PIN Block Formats	4-3
PIN Selection	4-3
Optional PINs	4-4
Use Strong PIN Verification Methods	4-4
Mask PVV Data	4-4

Key Handling	4-5
Split Knowledge and Dual Control.	4-5
Never Share Test and Production Keys	4-5
Unique Keys Per Device.	4-5
Periodic Key Changes.	4-6
Never Have Keys in the Clear	4-6
Hardware Security Devices.	4-7
Lock Down HSM Commands.	4-7
Never Share Production and Test HSMs	4-7
Lock Down LAN Connections	4-8
Lock Down Process Connections	4-8
Consult Vendor Manuals	4-8
Regular Software Updates	4-8
Physical and Logical Protection	4-8
Master Keys	4-8
A: Application Security Best Practices Checklist.	A-1
B: Compensating Controls for PCI	
DSS 3.4. B-1	
HP NonStop Compensating Controls	B-2
Constraints	B-2
Objective.	B-2
Identified Risk.	B-2
Definition of the Compensating Controls.	B-2
Index	Index-1

ACI Worldwide, Inc.

Preface

This document describes the security aspects of the BASE24 application and provides general best practices for securing the BASE24 application and surrounding logical environment.

Audience

This document is intended for security administrators, application managers, and persons responsible for the secure installation and configuration of the BASE24 system. Operations managers, security auditors, and change management personnel can also use this document when evaluating and implementing the security practices of your organization.

Prerequisites

This document is designed to be used in conjunction with your corporate information security policies. Readers should be familiar with internal policies and the security information in the *BASE24 User Security Manual* and the *BASE24 Transaction Security Manual*.

Additional Documentation

The BASE24 documentation set is arranged so that each BASE24 manual presents a topic or group of related topics in detail. When one BASE24 manual presents a topic that has already been covered in detail in another BASE24 manual, the topic is summarized and the reader is directed to the other manual for additional information. Information has been arranged in this manner to be more efficient for readers who do not need the additional detail and at the same time provide the source for readers who require the additional information.

This manual contains references to the following BASE24 publications:

- The ***BASE24 User Security Manual*** describes how to assign access to BASE24 screens. It also describes how to run audit reports on the Online Maintenance File (OMF).
- The ***BASE24 Logical Network Configuration File Manual*** contains detailed descriptions of the parameters used to configure system security.
- The ***ACI Desktop User Interface Manual*** describes user access configuration for those systems that use the Enhanced Authorization product or the Transaction Security Services process.
- The ***BASE24 Transaction Security Service Processing Guide*** describes processing and configuration for the Transaction Security Services process.
- The BASE24-atm device-specific device support manuals describe account number truncation on ATM receipts.
- the ***BASE24-atm Files Maintenance Manual*** describes PIN encryption fields in the BASE24-atm Terminal Data Files.
- The ***BASE24-pos Files Maintenance Manual*** describes PIN encryption fields in the BASE24-pos Terminal Data Files.
- The ***BASE24 Base Files Maintenance Manual*** describes PIN encryption fields in the Key File. It also discusses PIN options in the Card Prefix File.

In addition to BASE24 publications, this document contains references to the following industry standards:

- The ***Payment Card Industry Data Security Standard***, that is available through the Visa website is cited as a reference for industry security best practices.
- The ISO 17799 standard, ***Information Technology—Security Techniques Code of Practice for Information Security Management*** can assist you in identifying information security issues.
- The ANSI X9.24 standard, ***Retail Financial Services Symmetric Key Management***, can be used as a reference when developing PIN security and key management policies and procedures.

- The ANSI X9 TG-3 standard, *Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management*, can be used as a reference when developing PIN security and key management policies and procedures.
- *Payment Card Industry PIN Security Requirements*, can be used as a reference when developing PIN security and key management policies and procedures.

Software

This manual documents standard processing as of its publication date. Software that is not current and custom software modifications (CSMs) may result in processing that differs from the material presented in this manual. The customer is responsible for identifying and noting these changes.

Manual Summary

The following is a summary of the contents of this manual.

“Security Notice Disclaimer” follows this preface and contains ACI’s disclaimer regarding the use of this document.

Section 1, “Introduction,” introduces the reader to the considerations involved in setting your organization’s security practices plan.

Section 2, “Security Best Practices,” describes cross-industry best practices at a high level. It uses the *Payment Card Industry Data Security Standard* as a reference document, though there are many industry standards available.

Section 3, “Security Best Practices in the BASE24 Environment,” describes how to use BASE24 features to ensure industry security best practices.

Section 4, “PIN Security and Key Management,” describes BASE24 configuration considerations for PINs and keys.

Appendix A, “Application Security Best Practices Checklist,” contains a checklist for you to use when creating your organization’s security plan.

Appendix B, “Compensating Controls for PCI DSS 3.4,” describes ACI’s strategies for using compensating controls in place of data encryption on the HP NonStop platform.

Publication Identification

Three entries appearing at the bottom of each page uniquely identify this BASE24 publication. The publication number (for example, BA-AE000-16 for **BASE24 Security Best Practices**) appears on every page to assist readers in identifying the manual from which a page of information was printed. The publication date (for example, Aug-2011 for August 2011) indicates the issue of the manual. The software release information (for example, R6.0v10 for release 6.0, version 10) specifies the software that the manual describes. This information matches the document information on the copyright page of the manual.

Security Notice Disclaimer

This document contains important security information as it relates to ACI Worldwide, Inc. (ACI) products. ACI reserves the right, from time to time, to update the information in this document with current information.

Please note that computer security is a rapidly changing landscape. New attacks are constantly emerging. ACI recommends that you regularly consult with your company's security experts to ensure that your system is protected and in compliance with applicable laws.

THE INFORMATION PROVIDED HEREIN IS ADVISORY IN NATURE AND IS PROVIDED “AS IS” WITHOUT WARRANTY OF ANY KIND. WHILE ACI HAS ENDEAVORED TO BE ACCURATE AND TO PROVIDE INFORMATION FROM SOURCES WE BELIEVE TO BE ACCURATE, ACI DISCLAIMS (i) ALL WARRANTIES, EITHER EXPRESS OR IMPLIED, INCLUDING THE WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE OR (ii) ANY OBLIGATION TO UPDATE THIS INFORMATION.

ACI WILL NOT BE RESPONSIBLE FOR ANY DAMAGES YOU MAY INCUR, INCLUDING WITHOUT LIMITATION, DIRECT, INDIRECT, INCIDENTAL, CONSEQUENTIAL, SPECIAL, PUNITIVE, COVER, LOSS OF PROFITS, BUSINESS INTERRUPTION OR THE LIKE, OR LOSS OF BUSINESS DAMAGES, BASED ON ANY THEORY OF LIABILITY INCLUDING BREACH OF CONTRACT, BREACH OF WARRANTY, TORT (INCLUDING NEGLIGENCE), PRODUCT LIABILITY OR OTHERWISE, (WHETHER FORESEEABLE OR NOT) ARISING FROM USE OF, OR RELIANCE ON, THIS INFORMATION. SOME STATES DO NOT ALLOW THE EXCLUSIONS OR LIMITATION OF LIABILITY FOR CONSEQUENTIAL DAMAGES SO THE FOREGOING LIMITATION MAY NOT APPLY.

ACI Worldwide, Inc.

1: Introduction

BASE24 security best practices are based on industry security guidelines. Best practices advocate measures taken at the operating system and application software levels combined with strong internal policies to protect sensitive information.

Sensitive Information

This document focuses on protecting sensitive information. For the purposes of this document, sensitive information includes, but is not limited to, the following data:

- Track 2 information
- Cardholder names, addresses, and other personal information
- Primary account number (PAN)
- Personal identification number (PIN) and PIN offsets
- Card verification information
- PIN verification information
- Cryptographic keys
- Passwords

Setting Internal Policies

The practices described in this document can help reduce vulnerabilities in your BASE24 system. To protect sensitive information within your entire organization, industry practices recommend creating and enforcing internal information security policies. Policies can include, but are not limited to, protecting electronic data, printed data, and your system as a whole. Your policies should also include an incident response plan.

In maintaining an information security policy, you need to consider the following:

- How your security policy is established, documented, maintained, and distributed.
- Your daily operational security procedures.
- Documented usage policies for critical employee-facing technologies.
- Education of employees regarding importance of cardholder information security.
- Policy for third-parties with access to cardholder data.
- Development of an incident response plan.

Protecting Electronic Data

You should consider the following when creating policies regarding how your organization uses and stores electronic data:

- What data is required for interim processing related to your system, including but not limited to offline processing, store-and-forward processing, settlement, payment file transfers, historical research, and how electronic data is securely stored, handled, and purged.
- Ad-hoc tracing of production activity including the following:
 - ❑ Who has authority to perform traces?
 - ❑ Where this type of information is to be stored (be sure the server on which the data is stored is equally secured as production servers)?
 - ❑ Who can traces be shared with?
 - ❑ How can trace data be securely transferred from the server (encrypting the data before e-mailing or placing it out on an FTP server for pick up)?
 - ❑ How long is trace data maintained before purging?

- What naming structure might be adopted so that purging can be automated as needed if all trace data is stored on a particular directory on a secured server?
- Audit trails including automation, recording, and security.
- Reviewing logs, at least daily and maintaining audit history.

Protecting Printed Data

Printed data includes any media, including screens, that display sensitive information. Cross-industry best practices also recommend including all documentation, such as BASE24 publications (including this document), in your policies that ensure protection of printed data.

You should consider the following when creating internal policies:

- E-mail that contains sensitive data including if it is encrypted or masked and who can receive these e-mails such as support desks or senior management. Policies must include voice systems and other communication devices that enable you to view e-mail messages.
- Hard copies and screen prints of data in the clear including who has access to reports and screens, what is visible on reports and screens, and how the reports and screen prints that would be of security concern are stored and destroyed.
- Documentation of purging policies for production and test data.
- Documentation of your policy on encryption key management for all areas of encryption active on your system.

Protecting Systems and Networks

You should consider the following for all environments (e.g., production and test) and disaster recovery system data (e.g., firewalls and virus security software) when creating policies that protect your system as a whole:

- Control of third party access to your environments.
- Password policies that include not using default passwords from vendors.
- Configuration standards for all system components that include cross-industry best practices to handle all known security vulnerabilities.

- Your schedule for regularly updating anti-virus software and keeping systems and applications secure.
- Activation and deactivation of user IDs for employment status and job responsibility changes including what happens when an employee's status or responsibilities change. For example, the HR departments must review user access when employees leave the company, transfer, are promoted, etc. A periodic review of user IDs and permissions is worthwhile as well.
- Passwords for both employees and third parties (support help desks). For example, do you force password changes and require strong passwords?
- Password protection on screensavers to further protect secured data so that employees passing an empty work station can not readily gain access to the data.
- The time limit for how long a workstation can remain idle before the application is locked and requires a secure password for activation.
- How the created policies will be enforced and monitored.

Using This Document

The practices described in this document, when used as part of a system-wide security program, can help to secure the BASE24 environment. It is the responsibility of the user to secure the operating system and other compatible applications according to their own corporate information security policies.

This document was designed for use in conjunction with the ***BASE24 User Security Manual***, the ***Logical Network Configuration File Manual***, and the ***BASE24 Transaction Security Manual***. If your organization uses the Transaction Security Services process or the Enhanced Authorization process, the ***ACI Desktop User Interface Manual*** and the ***BASE24 Transaction Security Services Processing Guide*** can be used in conjunction with this document as well.

2: Security Best Practices

Cross-industry best practices define security requirements for the protection of sensitive data. The requirements support the following security goals:

- Build and maintain a secure network
- Protect cardholder data
- Maintain a vulnerability management program
- Implement strong access control measures
- Regularly monitor and test networks
- Maintain an information security policy and incident response plan
- Implement best practices for PIN security and key management

This section describes the best practices to support these goals. Refer to sections 3 and 4 for information about using the features of the BASE24 product to comply with cross-industry best practices.

Security Standard Reference

While there are many data protection standards available, this document follows the outline of the *Payment Card Industry Data Security Standard* (available on the Visa website at <http://www.visa.com/cisp> and <http://www.mastercard.com/sdp>). The standard is shown below:

Build and Maintain a Secure Network.

1. Install and maintain a firewall configuration to protect data.
2. Do not use vendor-supplied defaults for system passwords and other security parameters.

Protect Cardholder Data

3. Protect stored data.
4. Encrypt transmission of cardholder data and sensitive information across public networks.

Maintain a Vulnerability Management Program

5. Use and regularly update anti-virus software.
6. Develop and maintain secure systems and applications.

Implement Strong Access Control Measures

7. Restrict access to data by business need-to-know.
8. Assign a unique ID to each person with computer access.
9. Restrict physical access to cardholder data.

Regularly Monitor and Test Networks

10. Track and monitor all access to network resources and cardholder data.
11. Regularly test security systems and processes.

Maintain an Information Security Policy

12. Maintain a policy that addresses information security.

To aid in complying with these standards, ACI recommends consideration of the actions described on the following pages.

Build and Maintain a Secure Network

Installing and maintaining a firewall configuration and not using vendor-supplied default passwords are requirements for building and maintaining a secure network.

Install and Maintain a Firewall Configuration to Protect Data

Firewalls control computer traffic into your network from the outside, as well as traffic into sensitive areas within your network. A good firewall configuration includes both test and production environments.

The BASE24 product does not include a firewall. To comply with a requirement to maintain and install a firewall configuration to protect data, you must supply, outside of BASE24, a firewall product and set up your network securely. Cross-industry best practices recommend placing the database in an internal network zone that is segregated from the electronic demilitarized zone (DMZ). Running the application in a DMZ risks unauthorized access to the BASE24 database from the Internet.

ACI advocates installing the BASE24 product in its own security enclave, usually residing with other core processing systems. This enclave must be on its own network segment, protected by a firewall from the main financial institution network.

Access to the BASE24 product through the firewall must be restricted to explicit IP addresses and port IDs. The firewall must be configured to monitor the type of data on connections.

Note that no BASE24 software is delivered via remote access. Normal support activity can be performed using the WebEx conferencing tool, which allows ACI personnel to view what is taking place in an application. ACI does not use this tool to deliver patches or updates. ACI also does not make unsolicited contact with customers to initiate remote access to customers' systems. All remote support must be for a specific case. The customer can authenticate ACI support personnel via telephone by asking them to supply the correct case number. See the ACI Worldwide HELP24 Quick Reference Guide BASE24 document for information regarding how to create a case number.

Do Not Use Vendor-Supplied Defaults for System Passwords and Other Security Parameters

Hackers often use vendor-supplied passwords and other default settings to break into a network. You can use the BASE24 User Security screens to change default settings in BASE24 software only. You are responsible for changing default passwords in other applications, operating systems, and networks to ensure that you set up your environment securely.

Cross-industry best practices advocate the creation of information security policies that include the requirement to not use default passwords included with the BASE24 product or any other product used in your network.

In addition, the BASE24 product does not place restrictions on what services or protocols must be present to function. BASE24 is able to function both on unsecured and secured TCP/IP ports. You must take this into consideration when setting up network connections.

This requirement also includes the encryption of all nonconsole administrative access and recommends SSH, VPN, or SSL/TLS for web-based management and other nonconsole administrative access. The HP NonStop system does not have *built-in* capabilities to support the use of SSH or SSL/TLS. If you communicate with the server or application, you must purchase a separate product, such as ACI's Webgate product, to secure these connections.

Protect Cardholder Data

Protecting stored data and encrypting the transmission of cardholder data and sensitive information across public networks are requirements for protecting cardholder data.

Protect Stored Data

The BASE24 product gives you the option of not storing Track 2 data, such as card verification value (CVV), PVV data, and service codes. After authentication is complete, only the primary account number (PAN), expiration date, and member number are stored in the log files for acquirer transactions.

Note: PANs are always stored in the log files.

The issuer database, however, does contain sensitive cardholder data. You can use the BASE24 User Security screens to restrict access to this information.

Historical sensitive data or data stored by previous versions of software must be securely removed from the system. BASE24 automatically removes data from previous transactions after a configurable number of days. This is done to facilitate reversals. In order to be PCI compliant, the system must be configured to retain this data for not more than 7 days. See the ***BASE24 Logical Network Configuration File Manual*** for information on setting the SWI-ILF-FILE-RETENTION flag that controls this feature.

To be PCI compliant, cryptographic material stored by previous versions of BASE24 must be removed. See the ***BASE24 Transaction Security Manual*** for instructions regarding key handling and rotation.

Encrypt Transmission of Personally Identifiable Data and Sensitive Information Across Public Networks

Sensitive information such as cardholder data, account numbers, and government ID numbers (e.g., Social Security numbers, drivers license numbers) must be encrypted during transmission over a wireless transmission or the Internet, so that any information that may have been intercepted cannot be read.

Access points for wireless transmission must not be installed within the cardholder network environment. If you set up access points for wireless transmission in networks connected to the cardholder environment, they must be configured in

accordance with Wi-Fi best practices. Install perimeter firewalls between any wireless networks and the cardholder data environment, and configure these firewalls to deny or control (if such traffic is necessary for business purposes) any traffic from the wireless environment into the cardholder data environment. Wired Equivalent Privacy (WEP) must not be exclusively relied upon to protect confidentiality and access to a wireless LAN.

If WEP is used, do the following:

- Use with a minimum of 104-bit encryption key and 24 bit-initialization value
- Use **only** in conjunction with WiFi Protected Access (WPA or WPA2) technology, VPN, or SSL/TLS
- Rotate shared WEP keys quarterly (or automatically if the technology permits)
- Rotate shared WEP keys whenever there are changes in personnel with access to keys
- Restrict access based on media access code (MAC) address.

For new wireless implementations, it is prohibited to implement WEP after March 31, 2009. For current wireless implementations, it is prohibited to use WEP after June 30, 2010.

If you want to access the mainframe through a VPN tunnel, ACI advocates that strong encryption should be used for VPN connections.

If you establish a connection to the BASE24 product over the Internet, you must safeguard sensitive cardholder data. Secure Sockets Layer (SSL) or Transport Layer Security (TLS) is a typical approach to securing a session. It is the customer's responsibility to set up this tool.

Many industry standards include the use of e-mail. Note that the BASE24 application does not have built-in e-mail functionality, and unencrypted e-mail must never be used to send cardholder information.

Maintain a Vulnerability Management Program

Using and updating anti-virus software and developing and maintaining secure systems and applications are requirements for maintaining a vulnerability management program.

Use and Regularly Update Anti-Virus Software

Many viruses enter the network through employee e-mail. You must use and maintain anti-virus software on all e-mail systems, desktops, servers, and other entry points.

Develop and Maintain Secure Systems and Applications

Organizations must protect their web-based systems from exploitation by hackers or unscrupulous or careless employees. Although BASE24 is not a web-based system, cross-industry best practices recommend that you maintain a secure system by applying all security patches from other software vendors, by establishing processes to identify new security vulnerabilities, and by following industry secure-coding guidelines.

ACI follows strict guidelines for writing, testing, and delivering BASE24 code. Internal measures include the following:

- Documenting and testing all software changes before releasing the update, patch, or fix to the customer.
- All nonessential accounts, user IDs, and passwords are cleared from the application prior to the code being packaged for release.
- All code is reviewed multiple times to validate that standards are followed.

Implement Strong Access Control Measures

Restricting access to data by business need to know, assigning a unique ID to each person with computer access, and restricting physical access to cardholder data are requirements for implementing strong access control measures.

Restrict Access to Data by Business Need to Know

Restricting access to data to only those people who use the data for business purposes ensures that data is used in an authorized manner. Best practices advocate the following restrictions:

- Restricting access to financial institutions, regions, and branches to only those that a user needs to perform his or her job functions
- Restricting XPNET node access to only those used for business purposes
- Restricting the time of day that a user can access the system
- Restricting the terminals through which a user can access the system
- Restricting read, add, delete and update functions to only those that a user needs to perform his or her job functions

Assign a Unique ID to Each Person with Computer Access

Assigning a unique user ID (or *alias*) to each person with computer access ensures that actions are performed by the correct person and leaves an audit trail. Each user name (i.e., the name the user enters in the USER NAME field to access the BASE24 system) must be assigned to a user group and a unique user number.

Note: The user alias is for theBASE24 user access system only. It is your responsibility to assign unique IDs to each person at the operating system level.

Authentication and password management also includes locking out users after repeated failed login attempts or after their sessions have been idle for 15 minutes.

Implement two-factor authentication for remote access to the network by employees, administrators, and third parties. Use technologies such as remote authentication and dial-in service (RADIUS) or terminal access controller access control system (TACACS) with tokens; or VPN (based on SSL/TLS or IPSEC) with individual certificates.

Restrict Physical Access to Cardholder Data

You must restrict physical access to cardholder data. You can accomplish this by employing such measures as facility entry controls and developing strict visitor policies at your site. Cross-industry best practices recommend that computers that can access the BASE24 system be located in a secure location.

Regularly Monitor and Test Networks

In regularly monitoring and testing networks, you need to consider:

- The method used to link access to system components to individual users
- Your policy for audit trails including automation, recording, and security
- Your policy for reviewing logs, at least daily and maintaining audit history
- Your method for testing security controls
- Your plan for internal and external vulnerability scans and penetration testing
- Your use of network intrusion detection systems

Tracking and monitoring access to network resources and cardholder data regularly are requirements for this goal.

Track and Monitor All Access to Network Resources and Cardholder Data

Logging and tracking user access to the network and cardholder data enables you to trace system use when something does go wrong. A good tracking system logs all access by individual users and links administrative privileges to individual users.

Regularly Test Security Systems and Processes

Cross-industry best practices recommends that you regularly test security systems and processes for vulnerabilities.

Maintain an Information Security Policy and Incident Response Plan

In maintaining an information security policy, you need to consider:

- How your security policy is established, documented, maintained, and distributed
- Your daily operational security procedures
- Documented usage policies for critical employee-facing technologies
- Education of employees regarding importance of cardholder information security
- Policy for third-parties with access to cardholder data
- Development of an incident response plan

Maintain a Policy that Addresses Information Security

The cornerstone to effective data protection is the development of a comprehensive information security policy. Cross-industry best practices advocate maintaining a policy that addresses information security. This guide, along with the *Payment Card Industry Data Security Standard* or another industry standard, such as the ISO 17799 standard, *Information Technology—Security Techniques Code of Practice for Information Security Management*, can assist you in identifying information security issues.

Implement Best Practices for PIN Security and Key Management

Cross-industry best practices and card association operating rules prescribe strict policies, procedures, and controls over PINs and keys. The prevailing auditing standards that are enforced in the industry are the *Payment Card Industry PIN Security Requirements*, and ANSI X9 TG-3 standard, *American National Standard for Retail Financial Services Compliance Guideline—Online PIN Security and Key Management*.

PIN Encryption

PINs used for cardholder authentication must be protected using encryption. Best practices require specific ANSI-approved algorithms, key lengths, and PIN Pad formats.

PIN Verification

Card issuers must employ secure PIN verification algorithms, using appropriate key lengths and cryptographic strength.

Key Handling

Keys must be maintained in an encrypted form. Key loading and handling must be performed using split knowledge and dual control. Best practices require the use of unique keys per PIN entry device.

Hardware Security Devices

Hardware security devices must be used for all cryptographic operations involving PINs. This ensures the PINs are never in their clear text form. Certain policies and procedures must be in place to ensure the hardware security device is physically and logically secure, and configured in a manner that promotes the greatest protection for PINs and keys.

3: Security Best Practices in the BASE24 Environment

This section describes security considerations in the configuration and operation of a BASE24 application environment. These best practices can be effective in protecting sensitive data when used as part of a conscientiously applied program of risk management and vulnerability assessment.

The BASE24 product can help you address the following security requirements:

- Protect stored data
- Restrict access to data by business need-to-know
- Assign a unique ID to each person with computer access
- Track and monitor all access to network resources and cardholder data

The remainder of this document describes how the BASE24 product features can be used to comply with these requirements.

Protect Stored Data

You can protect stored data by following these precautions:

- Store only the information that is necessary
- Control access to the stored information
- Masking displayed information

Note: The BASE24 product does not mask or encrypt stored information.

Storing Transaction Information

You are responsible for restricting access at the application and operating system levels to files that contain sensitive data. The following is a sample list of files that contain sensitive data:

- Cardholder Authorization File
- Positive Balance File
- BASE24-atm Terminal Data Files
- BASE24-pos Terminal Data Files
- Store-and-Forward File
- XPNET Audit Files
- Dump files

Disclaimer: This may not be a complete list. You should perform your own assessment of BASE24 files and evaluate the sensitivity of the data in each file for yourself.

For acquirer and issuer transactions, it is possible to configure the BASE24 product to store and/or transmit sensitive authentication information, including full track information, service codes, card-validation codes, and PIN verification values (PVV). The default Logical Network Configuration File (LCONF) that is delivered with the BASE24 product has the parameters set to suppress storage and transmission of this sensitive authentication information. You are responsible to ensure that these configuration parameters are set to suppress storage and transmission of full track data in order to meet PCI-DSS requirements. Some interfaces may require this sensitive data to process reversals. However, modifying these parameters so that full track data is stored or transmitted will make the

system noncompliant with PCI-DSS requirements. The following is a list of LCONF parameters that must be set to the value Y to achieve PCI-DSS compliance. See the ***BASE24 Logical Network Configuration File Manual*** for a description of each parameter.

- Switch Parameters:
ELIMINATE-ACQ-TRK-DATA
SWI-ACQ-AVS-DATA-SUPPRS
SWI-ACQ-CVD2-DATA-SUPPRS
SWI-ACQ-DISCR-DATA-SUPPRS
SWI-ISS-AVS-DATA-SUPPRS
SWI-ISS-CVD2-DATA-SUPPRS
SWI-ISS-DISCR-DATA-SUPPRS
- ATM Parameters:
ATM-ACQ-DISCR-DATA-SUPPRS
ATM-DISCR-DATA-STM-SUPPRS
ATM-ISS-DISCR-DATA-SUPPRS
- POS Parameters:
POS-ACQ-AVS-DATA-SUPPRS
POS-ACQ-CVD2-DATA-SUPPRS
POS-ACQ-DISCR-DATA-SUPPRS
POS-DISCR-DATA-PSTM-SUPPRS
POS-ISS-AVS-DATA-SUPPRS
POS-ISS-CVD2-DATA-SUPPRS
POS-ISS-DISCR-DATA-SUPPRS

LCONF parameters are set and modified through the LNCF Param screen of the BASE24 CRT access system. See the ***BASE24 Logical Network Configuration File Manual*** for instructions regarding updating, adding, and deleting LCONF parameters.

You also must restrict access to the LCONF at the application and operating system level, so that these params are not compromised.

On the NonStop platform, files can be wiped by first setting the CLEARONPURGE option of the FUP SECURE command (refer to [“Using the CLEARONPURGE Option to Wipe Files”](#)).

The following files must use the CLEARONPURGE option to ensure that they are wiped when purged:

- Interchange Log File (ILF)
- Transaction Log File (TLF)
- POS Transaction Log File (PTLF)
- Store and Forward File (SAF)
- Resubmittal Store and Forward File (RSAF)

Note that the BASE24 product receives sensitive data and stores it in memory during the life of the transaction. The BASE24 product clears information from memory when the information is no longer needed to process a transaction. Also, you can configure the maximum Store-and-Forward File retries fields in the Host Configuration File and Interchange Configuration File to limit the number of times the Host Interface or Interchange Interface process can attempt to send the store-and-forward message before deleting it. The interface process attempts to send the store-and-forward message only as many times as specified in the field before deleting it.

Logical Network Configuration File parameters give you the ability to suppress the following types of sensitive authentication information:

- BASE24-pos acquirer address verification data
- BASE24-pos acquirer card verification data
- BASE24-pos acquirer discretionary data
- BASE24-atm acquirer discretionary data
- BASE24-pos issuer address verification data
- BASE24-pos issuer card verification data
- BASE24-pos issuer discretionary data
- Interchange Interface process address verification data
- Interchange Interface process card verification data
- Interchange Interface process discretionary data

Parameters that control this information are described in the ***BASE24 Logical Network Configuration File Manual***. Most card associations prohibit storing sensitive card information.

The BASE24 product does not store or use keys in an unencrypted form. All keys are generated and all cryptographic operations are performed by a tamper-resistant security module, such as Atalla, Thales e-Security, Eracom, or Bull host security modules. Refer to section 4 for more information about key management.

Transaction logs containing cardholder data are purged automatically based on configuration settings. The BASE24-atm and BASE24-pos transaction log files that contain cardholder data (TLF and PTLF respectively) are automatically purged by the settlement process based on LCONF parameters. Configure the following parameters to purge the TLF and PTLF logs.

Log File	Parameter
TLF	ATM-SETL-TLF-FILE-RETENTION
PTLF	POS-SETL-PTLF-FILE-RETENTION

Parameters that control this information are described in the *BASE24 Logical Network Configuration File Manual*.

Controlling Access to Stored Data

Cross-industry best practices advocate controlling access to files, screens, and reports that contain sensitive information.

The BASE24 product is designed to be used by individuals within an organization where their job functions require them to view full cardholder data. Instead of masking this data, ACI recommends granting limited access to those screens.

Controlling Access to Files and Screens

ACI recommends controlling the access to files and user screens where customer information is stored or displayed. Refer to the topic “Restrict Access to Data by Business Need-to-Know” later in this section for more information about controlling screen access.

It is your responsibility to restrict access to files at the operating system level.

Note: The XPNET product has an auditing function that allows the administrator the capability of turning on a process to log data to a file on disk for troubleshooting purposes. The log file contains full message text. It is the responsibility of the administrator to turn off the auditing function and securely destroy its output when no longer needed.

Customers should use the SafeGuard access control system, which provides extremely fine-grained access permission between subjects, and objects, including users, files, processes, and network ports. Appendix B contains information regarding the use of compensating controls to secure sensitive data within the BASE24 system.

The BASE24 product performs very little file control activity (create, open, delete). Logging of file control activity should be enabled for the volumes containing BASE24 files. These logs should be reviewed often for actions that are not associated with BASE24 file activity.

Controlling Access to Printed Reports

Should reports be printed from the BASE24 database, it is your responsibility to ensure that those reports are printed in areas where the information would not be easily accessed.

Masking Displayed Information

The BASE24-atm product enables you to mask cardholder information on customer receipts. By using the account number truncation feature, you can substitute blank spaces or pad characters for part of the card number and account numbers on ATM customer receipts. Cross-industry best practices recommend displaying only the last four digits or the first six digits. The middle six digits should never be displayed. Refer to the device-specific device support manuals for more information about account number truncation.

Note that the BASE24-pos product does not control POS receipt printing. It is your responsibility to communicate your organization's policies with your POS merchants.

Refer to section 4 for information about masking displayed PVV data.

Restrict Access to Data by Business Need-to-Know

Restricting access to information to only those who need it to perform their jobs ensures that critical data can only be accessed in an authorized manner. It is your responsibility to review the BASE24 user access screens and the associated documentation to determine whether the screens contain sensitive information that should be protected.

It is your responsibility to grant access to BASE24 screens on a business need-to-know basis only. You can use BASE24 Security screen 3 to define the type of access (read, add, delete, update) each user has to each BASE24 screen. The default value is no access. Refer to the *BASE24 User Security Manual* for more information about assigning screen access.

You can use the BASE24 user access security screens to restrict access to the BASE24 system as follows:

To Restrict a User's Access to...	Use this Screen
Information at the financial institution level	Security File, screen 2
Information at the regional or branch level	Security File, screen 2
The XPNET node to which commands are sent	Security File, screen 1
Information based on the time of day	Security File, screen 1
Terminals that can be used to access BASE24 data	Security File screen 1
BASE24 user access screens containing sensitive information	Security File screen 3

Because a single user can have access to multiple logical networks, you can use these screens to configure restrictions on each logical network to which the user has access.

Refer to the ***BASE24 User Security Manual*** for more information about using the Security File screens to restrict access using these controls. If you have the Enhanced Authorization product or the Transaction Security Services product, refer to the ***ACI Desktop User Interface Manual*** for more information about assigning access to the ACI desktop user interface.

Note: The procedures described here restrict access to the BASE24 screens only. It is your responsibility to restrict access to files at the operating system level.

Assign a Unique ID to Each Person with Computer Access

Unique user IDs ensure that actions taken on critical data and systems are performed by, and can be traced to, known and authorized users. The BASE24 product allows you to configure unique user IDs and passwords. A user ID and password are required to log on to the BASE24 user access system. Your security practices also must address lock-out policies.

Administrative IDs

Personnel who perform administrative duties (for example, setting screen access for all other users of the BASE24 system) must log on to the system with a unique ID. Cross-industry best practices recommend reserving the use of administrative IDs to a security officer in your organization. Note that these IDs are meant for administrative purposes and should not be used to access the application for day to day use.

Refer to the *BASE24 User Security Manual* for more information about configuring IDs.

User IDs

Each user of your BASE24 system should have a unique user ID and password. Cross-industry best practices recommend not using IDs that are meant to be shared by multiple users. BASE24 Security screen 1 enables you to create user IDs and assign passwords. If your organization uses the Enhanced Authorization product or the Transaction Security Services process, you also must configure unique IDs for the ACI desktop user interface.

Refer to the *BASE24 User Security Manual* for more information about assigning access and the Security File screens. Refer to the *ACI Desktop User Interface Manual* for more information about assigning access to the ACI desktop user interface

Note: The procedures described here are for setting unique IDs for the BASE24 user access system only. It is your responsibility to assign unique IDs to each person at the operating system level.

Cross-industry best practices recommend immediately revoking access by terminated users and removing inactive user accounts every 90 days.

Passwords

All user IDs must be associated with a password to ensure that only authorized users can log on to the BASE24 user access system.

Users are required to enter their passwords on the BASE24 Logon screen.

As you create user IDs for BASE24 users, you must set first-time passwords to a unique value per user. Cross-industry best practices recommend requiring users to change their first-time passwords immediately after first use. Refer to the ***BASE24 User Security Manual*** for more information about changing passwords.

ACI recommends distributing password policies and procedures to all users who have access to cardholder information.

Passwords stored in the BASE24 system are encrypted.

Cross-industry best practices advocate the use of complex passwords, password aging, and password histories to prevent unauthorized users from using an ID by guessing the password.

Complex Passwords

Cross-industry best practices advocate the use of complex passwords for all BASE24 logons. You can specify the use of complex passwords by setting the complex passwords parameter in the Logical Network Configuration File. If the parameter is set to require complex passwords, you then can specify the minimum length of the password; whether the password is case sensitive; the number of alphabetic, numeric, and special characters required; the password change interval; and the number of passwords stored.

Best practices standards recommend that complex passwords have the following characteristics:

Complex Password Characteristic	Logical Network Configuration File Parameter
Minimum password length of seven characters	Minimum password length
Use of alphabetic, numeric, and special characters	Minimum number of alphabetic characters Minimum number of numeric characters Minimum number of special characters
Mixed case	Complex password
Change password at least every 90 days	Password change interval
Do not allow a password that is the same as any of the last four passwords	Maximum passwords stored

Refer to the *BASE24 User Security Manual* for more information about complex passwords. Refer to the *BASE24 Logical Network Configuration File Manual* for more information about the Logical Network Configuration File parameters related to passwords.

Password Aging

Passwords must be changed frequently to reduce risks of compromised passwords. Cross-industry best practices advocate requiring users to change their passwords at least every 90 days. You can use the password change interval parameter in the Logical Network Configuration File to configure how often a password must be changed.

You also can configure the number of times a day a password can be changed using the maximum password changes per day parameter in the Logical Network Configuration File.

Password Histories

Cross-industry data security standards recommend not allowing an individual to submit a new password that is the same as any of the last four passwords he or she has used. The Logical Network Configuration File maximum stored passwords parameter specifies the number of passwords stored in the password history. The BASE24 product allows up to 10 passwords to be stored in the password history. A user is unable to reuse any password contained in his or her password history.

System Lockout

Cross industry data security standards recommend locking users out of the system after no more than six login attempts or after the session has been idle for 15 minutes.

The maximum logon attempts Logical Network Configuration File parameter and corresponding field in the Security File specify the number of unsuccessful login attempts a user can have before being locked out of the BASE24 environment.

The logoff interval configured in the Logical Network Configuration File and the Security File specify the length of time a session can be idle before logging the user out.

Track and Monitor All Access to Network Resources and Cardholder Data

The BASE24 product uses the Online Maintenance File (OMF) to store detailed information about each BASE24 record that is added, deleted, or updated using the BASE24 user access system.

You can configure auditing by setting the Logical Network Configuration File parameter for OMF audit.

ACI recommends using the OMF to track access to cardholder data and to run the OMF report often. To achieve PCI compliance, OMF auditing must be enabled.

Refer to the *BASE24 Logical Network Configuration File Manual* for more information about the OMF audit parameter. Refer to the *BASE24 User Security Manual* for information about running OMF audit reports.

Note: The BASE24 product has the capability of running in debug mode. Customers should use this function very carefully, as the information being placed in the debug files has extremely sensitive information pertaining to cardholder information. Customers should collect data only when it is needed to solve a specific problem. Customers should store the data in a specific location with limited access and encrypt the data while it is stored. When customers are done with debug processing, they should ensure debug files are wiped (not deleted) from the system and that debugging has been disabled.

Using the CLEARONPURGE Option to Wipe Files

On the HP NonStop platform, files can be wiped by first setting the CLEARONPURGE option of the FUP SECURE command. For example, execute the following FUP commands to wipe the file *myfile*:

```
FUP SECURE myfile, , CLEARONPURGE  
PURGE myfile
```

Note: The CLEARONPURGE option, available for diskfiles, may be set to physically overwrite the residual data from any files that have been deleted (i.e. purged). Because every block of the purged file is overwritten with binary zeros, CLEARONPURGE requires extra I/O operations and disk channel time. This added overhead increases proportionally with file size. The increase is minimal on a small file, but can be many minutes of elapsed time on a large file. CLEARONPURGE should be designated for files containing particularly sensitive data. Other files should be evaluated by the organization to weigh the risk of not clearing the deleted file against system performance considerations.

4: Best Practices for PIN Security and Key Management in the BASE24 Environment

This section contains options for securing PINs and key management in the BASE24 environment. Best practices include consideration for the following areas:

- PIN encryption
- Key handling
- Hardware security devices

Policies and procedures for PIN security and key management should be developed according to the following industry standards:

- The ANSI X9.24 standard, *Retail Financial Services Symmetric Key Management*
- The ANSI X9 TG-3 standard, *Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management*
- *Payment Card Industry PIN Security Requirements*

PIN Encryption

Cross-industry best practices for PIN encryption include the following standards:

- PINs must be encrypted
- Use strong PIN block formats
- Restrict first-time PIN selection at the ATM
- Do not allow optional PINs
- Use strong PIN verification methods
- Mask PVV data

The following paragraphs describe cross-industry best practices for PIN encryption and their implementation in the BASE24 environment.

PINs Must be Encrypted

Cross-industry best practices and all card associations and networks have mandated that PINs must be encrypted, and never appear *in the clear* outside of a tamper-resistant security module. This requirement extends to any type of storage device, internal memory, inter-process I/O, error messages, audit logs, and traces. In summary, PINs must remain encrypted throughout their lifetime.

You can configure BASE24 Device Handler processes so that encryption is enabled for incoming messages, and for messages forwarded to other BASE24 applications by setting the PIN ENCRYPT TYPE field on BASE24-atm Terminal Data Files screen 9 or the PIN ENCRYPTION TYPE field on BASE24-pos Terminal Data Files screen 7 to a valid value other than 00. Likewise, you can configure Interchange Interface processes to send and receive PINs in an encrypted form, and process PINs in an encrypted form internally by setting the ENCRYPT TYPE and BASE24 ENCRYPT TYPE fields on Key File screen 1 to the value 1.

Refer to the ***BASE24-atm Files Maintenance Manual*** for more information about the BASE24-atm Terminal Data Files. Refer to the ***BASE24-pos Files Maintenance Manual*** for more information about the BASE24-pos Terminal Data Files. Refer to the ***BASE24 Base Files Maintenance Manual*** for more information about the Key File.

Triple DES and Key Lengths

Card associations, networks, and ANSI X9 auditing standards require all keys to be at least double length, using the triple DES algorithm. This includes keys used to protect other keys (e.g., key exchange keys), and session keys (e.g., PIN keys, MAC keys, data encryption keys, CVV keys).

Triple DES should be selected as the algorithm for PIN encryption. This applies for transactions acquired from ATM and POS devices, from interchanges, and processing within the BASE24 system. Triple DES requires double- or triple-length keys, which should be configured in the Transaction Security Services (TSS) database, or in the KEY6 File. The triple-single DES parameter in the Logical Network Configuration File specifies the encryption algorithm for Interchange Interface processes.

PIN Block Formats

Most card associations do not allow the use of PIN PAD PIN block formats, as they are subject to certain cryptographic attacks. The use of ISO Format 0 (ANSI) PIN block formats is preferred.

ATM loads must be set to configure ATMs to use the appropriate PIN block formats. PIN encryption fields in the BASE24-atm Terminal Data Files and the BASE24-pos Terminal Data Files control the PIN block format for the BASE24-atm and BASE4-pos products, respectively. The PIN block format field in the Key File controls the PIN block format for Interchange Interface processes.

PIN Selection

Certain options may exist to allow customers to select *first time* PINs at ATMs. This option introduces the risk that an adversary could generate a PIN for a stolen card. This BASE24 option should be disabled unless the risk is determined to be acceptable. The default is to disable this option. The Card Prefix File CARDHOLDER PIN SELECT field controls the customer PIN select option. Refer to the ***BASE24 Base Files Maintenance Manual*** for more information about the Card Prefix File.

Optional PINs

PIN-enabled cards should not be approved without PIN verification. Ensure that configuration options are set to enforce PIN verification. Environments that allow pre-validation of PINs (e.g., verification at an ATM) are considered greater risk because bad PIN tries cannot be tracked in a central location.

To allow the BASE24 system to manage all PIN verification, ATMs must be configured to forward encrypted PINs in all cardholder transactions. Local PIN verification at the devices should be disabled. The LOCAL PIN VERIFY fields in the BASE24-atm Terminal Data Files indicate whether an ATM can perform local PIN verification.

PIN verification parameters should be set to decline all PIN-capable transactions that do not contain PINs, and *bad PIN try* velocity checking should be enabled. Require PINs on every transaction by setting the Card Prefix File PIN PROCESSING FLAG field. Monitor bad PIN tries using bad PIN tries fields in the Card Prefix File and the Usage Accumulation File.

Use Strong PIN Verification Methods

Several PIN verification methods exist, such as Visa PVV and IBM3624 DES. Methods using double length PIN verification keys, such as the Visa PVV method, provide stronger resistance to attacks against the PIN verification key. Issuers should choose the strongest method available, the longest key length possible, and the longest PIN length feasible for their consumers.

Mask PVV Data

An adversary that is exposed to multiple PIN verification values (PVVs), also known as PIN offsets, may be able to systematically determine PINs. Where possible, PVV values should be masked or not displayed on user screens.

BASE24 enables you to mask PIN offset information on the Cardholder Authorization File. This option should be enabled by setting the mask PIN offset PVV parameter in the Logical Network Configuration File.

Key Handling

Cross-industry best practices for key handling include the following standards:

- Split knowledge and dual control
- Never share test and production keys
- Use unique keys for each device
- Change keys on a periodic basis
- Never have keys in the clear

The following pages describe cross-industry best practices for key handling and how to implement these practices in the BASE24 environment.

Split Knowledge and Dual Control

Cross-industry best practices and card associations mandate that keys must never appear in the clear outside of a tamper-resistant security module unless they are in split components. Policies and procedures must be in place to ensure dual control during generation and distribution of keys. No one individual should possess the clear text key or all its key parts.

Never Share Test and Production Keys

Cross-industry best practices and card associations require that keys used in production are never used in a test environment or in test devices. Likewise, test keys must never be used in a production environment or production devices. Separate hardware security devices, ATMs, POS devices, and host systems must be employed for testing purposes.

Unique Keys Per Device

Cross-industry best practices and card associations require unique master keys and working keys to be used per device. No two PIN entry devices may use the same key, except by chance.

Periodic Key Changes

Cross-industry best practices suggest keys should be changed on a periodic basis. The ANSI X9.24 standard, *Retail Financial Services Symmetric Key Management*, recommends keys be changed in a period of time shorter than it takes to exhaustively determine a key.

The BASE24-atm Enhanced Key Management application can provide automated key changes for all ATM session keys. The BASE24 Automated Key Distribution System (AKDS) provides a mechanism to deploy master keys electronically in a secure manner, avoiding human entry of ATM master keys.

Never Have Keys in the Clear

Cross-industry best practices and card associations require keys to be in an encrypted form unless they are held within a tamper resistant security device, or stored in component form. Parameters should be set so that keys are entered, generated, transmitted, received, and processed in an encrypted form.

Hardware Security Devices

Cross-industry best practices for hardware security devices include the following standards:

- Lock down hardware security module (HSM) commands
- Never share production and test HSMs
- Lock down LAN connections
- Lock down process connections
- Consult vendor manuals
- Update software regularly
- Provide physical and logical protection
- Master keys must be generated and managed under principles of split knowledge and dual control

The following paragraphs describe cross-industry best practices for hardware security devices. It is your responsibility to secure all devices used with the BASE24 system.

Lock Down HSM Commands

Many HSM models allow host commands and administrative functions to be *locked down*. Administrative functions should be configured to require dual control, and on a *need to know* basis. All host commands should be disabled unless required by the application.

Never Share Production and Test HSMs

Cross-industry best practices and many network operating rules prohibit sharing a security device between a test and production system. Separate HSMs must be dedicated to production systems, containing only production keying material.

Lock Down LAN Connections

In order to minimize the opportunity for detecting traffic to an HSM over a TCP/IP connection, the HSM's network connections should be configured to communicate with the intended host application only, and limited to a single sub-net.

Lock Down Process Connections

Applications, operating systems, and network connections should be configured so that only legitimate host applications can communicate with the HSMs.

Consult Vendor Manuals

Users should regularly consult HSM vendor manuals and follow vendor recommendations for best practices, policies, and procedures.

Regular Software Updates

HSM users should implement policies and procedures to regularly update HSMs with the most current software available.

Physical and Logical Protection

Policies and procedures should be in place to ensure access to HSMs are limited to authorized personnel.

Master Keys

HSM master keys must be generated and managed under principles of split knowledge and dual control. Keys must be encrypted using a key encrypting key of equal or greater strength. For example, if using double length key exchange keys, the HSM master key must be at least double length, if not triple length. The longer the key, the greater protection against key exhaustion attacks.

A: Application Security Best Practices Checklist

This appendix contains a checklist you can use when creating your organization's security policies and practices.

✓	Control Objective	BASE24 Configuration	Reference
	Storing Transaction Information	Lock down files. Lock down user permissions. Turn off logging and transmission of Track 2 data by setting the following LCONF parameters to Y: • Switch Parameters: ELIMINATE-ACQ-TRK-DATA SWI-ACQ-AVS-DATA-SUPPRS SWI-ACQ-CVD2-DATA-SUPPRS SWI-ACQ-DISCR-DATA-SUPPRS SWI-ISS-AVS-DATA-SUPPRS SWI-ISS-CVD2-DATA-SUPPRS SWI-ISS-DISCR-DATA-SUPPRS • ATM Parameters: ATM-ACQ-DISCR-DATA-SUPPRS ATM-DISCR-DATA-STM-SUPPRS ATM-ISS-DISCR-DATA-SUPPRS • POS Parameters: POS-ACQ-AVS-DATA-SUPPRS POS-ACQ-CVD2-DATA-SUPPRS POS-ACQ-DISCR-DATA-SUPPRS POS-DISCR-DATA-PSTM-SUPPRS POS-ISS-AVS-DATA-SUPPRS POS-ISS-CVD2-DATA-SUPPRS POS-ISS-DISCR-DATA-SUPPRS	HP Nonstop Manuals <i>BASE24 User Security Manual</i> <i>BASE24 Logical Network Configuration File Manual</i>

✓	Control Objective	BASE24 Configuration	Reference
	Controlling Access to Files and Screens	Lock down Pathway access. Lock down Transaction Security Services access. Restrict access at operating system level.	<i>BASE24 User Security Manual</i> <i>BASE24 Transaction Security Services Processing Guide</i>
	Controlling Access to Printed Reports	No BASE24 configuration, but ensure that printers are in areas where information is not easily accessed.	
	Restrict Access to Data by Business Need-to-Know	Define type of access (read, add, delete, update) on Security File screen 3. Restrict access to information at the financial institution level on Security File screen 2. Restrict access to information at the regional or branch level on Security File screen 2. Restrict access to the XPNET node to which commands are sent on Security File screen 1. Restrict access to information based on the time of day on Security File screen 1. Restrict access to terminals that can be used to access to BASE24 data on Security File screen 1.	<i>BASE24 User Security Manual</i> <i>Continued on the following page</i>

✓	Control Objective	BASE24 Configuration	Reference
	Restrict Access to Data by Business Need-to-Know <i>continued</i>	Restrict Access to BASE24 user access screens containing sensitive information on Security File screen 3. You also must restrict access to files at the operating system level.	
	Assign a Unique ID to Each Person with Computer Access	Configure unique IDs for the BASE24 system using the Security File screens.	<i>BASE24 User Security Manual</i>
	Administrative IDs	Configure unique IDs for each person who logs on to BASE24 to perform administrative tasks.	<i>BASE24 User Security Manual</i>
	User IDs	Assign a unique user ID for each person who accesses the BASE24 system using the Security File screens.	<i>BASE24 User Security Manual</i>
	Passwords	Assign a unique password for each user ID. Set Complex Passwords parameter to require complex passwords. Set Minimum Password Length parameter to require at least seven characters.	<i>BASE24 User Security Manual</i> <i>BASE24 Logical Network Configuration File Manual</i> <i>Continued on the following page</i>

✓	Control Objective	BASE24 Configuration	Reference
	Passwords <i>continued</i>	Require a mixture of alphabetic, numeric, and special characters by setting the Minimum Number of Alphabetic Characters, Minimum Number of Numeric Characters, and Minimum Number of Special Characters parameters to values greater than 0. Set Password Change Interval parameter to specify that passwords must be changed at least every 90 days. Set the Maximum Passwords stored parameter to specify that a password cannot be the same as any of the last four passwords.	
	Track and Monitor All Access to Network Resources and Cardholder Data	Set the OMF audit parameter to enable auditing.	<i>BASE24 Logical Network Configuration File Manual</i>
	PINs Must be Encrypted	Configure Device Handler processes and Interchange Interface processes to require encrypted PINs in the following configuration files: BASE24-atm Terminal Data Files PIN ENCRYPT TYPE field BASE24-pos Terminal Data Files PIN ENCRYPTION TYPE field Key File ENCRYPT TYPE field Key File BASE24 ENCRYPT TYPE field	<i>BASE24-atm Files Maintenance Manual</i> <i>BASE24-pos Files Maintenance Manual</i> <i>BASE24 Base Files Maintenance Manual</i> <i>BASE24 Transaction Security Manual</i>

✓	Control Objective	BASE24 Configuration	Reference
	Configure Triple DES	For Interchange Interface processes, set the DES-TRIPLE-SINGLE parameter. For Device Handler processes, implement the Transaction Security Services process using double-length keys in the Channel Security data source and Interface Security data source.	<i>BASE24 Transaction Security Manual</i>
	Triple DES and Key Lengths	For the BASE24-atm and BASE24-pos products, configure the Transaction Security Services database. For Interchange Interface processes, use ANSI Blocks (i.e., ISO Format 0, PIN/PAN) in the Key File PIN ENCRYPT TYPE field. Set Key File, Key 6 File PIN BLOCK FOMAT field.	<i>BASE24 Transaction Security Services Processing Guide</i> <i>BASE24 Transaction Security Manual</i> <i>BASE24 Base Files Maintenance Manual</i>
	PIN Block Formats	For Interchange Interface processes, set the Key File PIN BLOCK FORMAT field. For Device Handler processes, set PIN ENCRYPT TYPE field in the BASE24-atm Terminal Data Files or PIN ENCRYPTION TYPE field in the BASE24-pos Terminal Data Files.	<i>BASE24 Transaction Security Manual</i> <i>BASE24 Base Files Maintenance Manual</i>
	PIN Selection	Lock down Customer PIN Select option using the Card Prefix File CARDHOLDER PIN SELECT field.	<i>BASE24 Transaction Security Manual</i> <i>BASE24 Base Files Maintenance Manual</i>

✓	Control Objective	BASE24 Configuration	Reference
	Optional PINs	Disable local PIN verification for ATMs by setting the LOCAL PIN VERIFY fields in the BASE24-atm Terminal Data Files. Require PINs on every transaction by setting the Card Prefix File PIN PROCESSING FLAG field.	<i>BASE24-atm Files Maintenance Manual</i> <i>BASE24 Transaction Security Manual</i> <i>BASE24 Base Files Maintenance Manual</i>
	Use strong PIN verification Algorithms	Configure the PIN CHECK TYPE field of the Card Prefix File to specify the Visa PVV PIN Verification algorithm.	<i>BASE24 Transaction Security Manual</i> <i>BASE24 Base Files Maintenance Manual</i>
	Mask PVV data	Mask the PIN Verification Values (PVVs) by setting the Mask PIN offset PVV parameter.	<i>BASE24 Transaction Security Manual</i>
	Key handling	Consult industry standards for a comprehensive description of proper key handling.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>

✓	Control Objective	BASE24 Configuration	Reference
	Split Knowledge and Dual Control	Keys must be under dual control and split knowledge, or encrypted, when outside the protection of an HSM or PIN Entry Device (PED).	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Never share test and production keys	Any keys used in a test environment must never be used in a production environment. Any keys used in a production environment must never be used in a test environment.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Unique keys per device	Each POS, ATM, or PIN entry device must contain unique master keys.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>

✓	Control Objective	BASE24 Configuration	Reference
	Periodic key changes	Keys must be changed on a periodic basis.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i>
	Never have keys in the clear	Keys must never appear in clear text form outside a tamper resistant security device (HSM).	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Hardware Security Devices	All keys and cryptographic operations must be performed under the protection of a Tamper-Resistant Security Module (aka, Host Security Module/HSM).	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>

✓	Control Objective	BASE24 Configuration	Reference
	Lock down HSM commands	Any HSM commands not needed for production should be disabled.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Never share production and test HSMs	HSMs must not be shared between test and production systems.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Lock down LAN connections	HSMs should be inaccessible from other network segments, and only accessible from legitimate servers.	
	Lock down process connections	HSMs should be inaccessible to all but authorized applications.	
	Consult Vendor Manuals	Vendor manuals should provide best practices for your make and model of HSM.	Vendor Manuals

✓	Control Objective	BASE24 Configuration	Reference
	Regular Software Updates	HSMs should be updated with current firmware and bug fixes.	HSM Vendor
	Physical and Logical Protection	Physical and logical access to an HSM must be limited to authorized personnel.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>
	Master Keys	Keys must be encrypted using a key encrypting key of equal or greater strength.	ANSI X9.24 standard, <i>Retail Financial Services Symmetric Key Management</i> ANSI X9 TG-3 standard, <i>Retail Financial Services Compliance Guideline—Part 1: Online PIN Security and Symmetric Key Management</i> <i>Payment Card Industry PIN Security Requirements</i>

ACI Worldwide, Inc.

B: Compensating Controls for PCI DSS 3.4

The PCI Data Security Standard, v.1.1, states that compensating controls may be used in place of data encryption in accordance with appendix B in that document. ACI recommends different strategies for each of our supported platforms (for BASE24, this is the HP NonStop platform) in support of Section 3.4 of this standard.

HP NonStop Compensating Controls

ACI has identified the following considerations when using compensating controls on the HP NonStop platform.

Constraints

Adding application level encryption will result in significant performance impacts. Additionally, encrypting the PAN, when used as a database key, provides weak cryptographic protection due to the small range of the PAN (15 digits plus Lund checksum), potentially shortened further by having a known BIN prefix and the inability to salt the cleartext. ACI has therefore concluded that encryption for cardholder data is not practical at this time.

Objective

The objective of encrypting PAN data is to protect it from anyone not authorized to view or download the information by rendering the data unreadable. The objective of the compensating control is to provide stronger access and auditing controls that provide fine grained protection.

Identified Risk

Additional risk is introduced into the system by not rendering the PAN information unreadable. An intruder or unauthorized insider that is able to circumvent all security controls will have access to the PAN information.

Definition of the Compensating Controls

Additional network segmentation must be provided by the end-user. The HP NonStop must be installed in its own security enclave. This enclave must reside on its own network segment, protected by a firewall from the main financial institution network.

Access to the HP NonStop through the firewall must be restricted to explicit IP addresses and port IDs. The firewall must be configured to monitor the type of data on connections. User IDs and roles must be configured in accordance with ACI user documentation.

The HP NonStop uses the SafeGuard access control system, which provides extremely fine-grained access permission between subjects and objects, including users, files, processes, and network ports. ACI applications perform very little file control activity (create, open, delete). Logging of file control activity must be enabled for the volumes containing the application files. These logs must be reviewed often for non-application file activity.

The HP NonStop file system attribute CLEARONPURGE can be used to force files to be securely deleted (wiped) when purged. This attribute must be set on all files containing sensitive data.

Access to the Enscribe databases requires local HP NonStop user accounts, configured locally on the system. No access by systems outside the processing enclave is ever required. The Enscribe database system on the HP NonStop does not support SQL.

The SQL/MX database is accessed through the application. Prepared statements and input validation are implemented within the user interface to defend against common database attacks such as SQL injection and XSS. Database vulnerabilities are also detected during development of the application through the use of both static and dynamic security scanning tools. Scan results are reviewed by the Security Engineering department and corrected by the product development team prior to release of the application.

ACI Worldwide, Inc.

Index

A

- Access control measures, [2-8](#)
- Administrative IDs, [3-9](#)
- Anti-virus software, [2-7](#)
- Application security best practices checklist, [A-1](#)
- ATM customer receipts, masking cardholder information, [3-6](#)
- Authentication information, parameters for suppressing, [3-4](#)

B

- BASE24 files, controlling access to, [3-5](#)
- BASE24 user access system
 - controlling access to, [3-5](#)
 - defining user access, [3-7](#)
 - unique user IDs, [2-8](#)

C

- Cardholder data
 - masking on ATM receipts, [3-6](#)
 - protecting, [2-5](#)
 - restricting physical access, [2-9](#)
- CLEARONPURGE option, [3-14](#)
- Compensating controls, HP NonStop strategies, [B-1](#)

D

- Debug mode, recommendations for running, [3-13](#)
- Default settings, BASE24 software, [2-4](#)

E

- Electronic data, security policy considerations, [1-3](#)
- E-mail, [2-6](#)
- Encryption
 - nonconsole administrative access, [2-4](#)
 - transmissions across public networks, [2-5](#)

F

- Firewalls, [2-3](#)

H

- Hardware security devices
 - HSM commands, [4-7](#)
 - LAN connections, [4-8](#)
 - logical protection, [4-8](#)
 - master keys, [4-8](#)
 - physical protection, [4-8](#)
 - process connections, [4-8](#)
 - production and test HSM usage, [4-7](#)
 - regular software updates, [4-8](#)
 - standards, [4-7](#)

I

- Information security policies
 - considerations, [1-3](#), [2-11](#)
 - protecting electronic data, [1-3](#)
 - protecting printed data, [1-4](#)
 - protecting systems and networks, [1-4](#)
- Internet connections, securing a session, [2-6](#)

K

- Key handling
 - best practices, [4-5](#)
 - dual control, [4-5](#)
 - keys in the clear, [4-6](#)
 - periodic key changes, [4-6](#)
 - split knowledge, [4-5](#)
 - test and production key usage, [4-5](#)
 - unique keys per device, [4-5](#)
- Key management
 - hardware security devices considerations, [2-12](#)
 - key handling considerations, [2-12](#)

L

- Logical Network Configuration File parameters, for suppressing authentication information, [3-4](#)

N

- Network
 - considerations for monitoring and testing, [2-10](#)
 - logging and tracking user access, [2-10](#)
 - security policy considerations, [1-4](#)
 - standards for building and maintaining, [2-3](#)
- Network resources, tracking and monitoring access, [3-13](#)

O

Online Maintenance File (OMF), [3-13](#)
Optional PINs, [4-4](#)

P

Passwords
 complex passwords, [3-10](#)
 considerations for policies, [3-10](#)
 histories, [3-12](#)
 password aging, [3-11](#)
Payment Card Industry Data Security Standard, [2-2](#)
PIN block formats, [4-3](#)
PIN encryption
 key lengths, [4-3](#)
 triple DES, [4-3](#)
PIN security
 PIN encryption considerations, [2-12](#)
 PIN verification considerations, [2-12](#)
PIN selection, [4-3](#)
PIN verification methods, [4-4](#)
Printed data, security policy consideration, [1-4](#)
PVV data, [4-4](#)

R

Reports, controlling access to, [3-6](#)
Restricting access by business need-to-know, [3-7](#)
Restricting access to data, [2-8](#)

S

Secure Sockets Layer (SSL), [2-6](#)
Security patches, applying, [2-7](#)
Security systems and processes, testing, [2-10](#)
Sensitive information
 definition, [1-2](#)
 encrypting, [2-5](#)
Store-and-forward messages, [3-4](#)
Stored data, controlling access to, [3-5](#)
Stored data, protecting, [2-5](#)
Storing transaction information, BASE24 files, [3-2](#)
System passwords, [2-4](#)

T

TCP/IP ports, [2-4](#)
Transport Layer Security (TLS), [2-6](#)
Triple DES, [4-3](#)

U

User IDs, [3-9](#)

V

Vulnerability management program, maintaining, [2-7](#)

W

Wiping files using the CLEARONPURGE option, [3-14](#)
Wired Equivalent Privacy (WEP), guidelines for using, [2-6](#)
Wireless transmission, access points, [2-5](#)